

HỌC VIỆN CÔNG NGHỆ BƯU CHÍNH VIỄN THÔNG
KHOA AN TOÀN THÔNG TIN



Môn Học: Thực Tập Cơ Sở
Báo Cáo Thực Hành Bài 13
Tấn Công Mật Khẩu

Giảng viên: TS. Phạm Hoàng Duy
Sinh viên: Hoàng Anh Khoa
Mã sinh viên: B22DCAT164
Hệ đào tạo: Đại học chính quy

Hà Nội, 4/2025

Mục lục

1. Mục đích	2
2. Nội dung thực hành	2
2.1. Cơ sở lí thuyết:	2
2.2. Các bước thực hiện	5
2.2.1. Chuẩn bị môi trường	5
2.2.2. Crack mật khẩu trên Windows	5
2.2.3. Crack mật khẩu trên Windows	8
3. Kết luận	11
4. Tài liệu tham khảo	11

Môn học Thực tập cơ sở

Bài 13: Tấn công mật khẩu

1. Mục đích

- Hiểu được mối đe dọa về tấn công mật khẩu.
- Hiểu được nguyên tắc hoạt động của một số công cụ Crack mật khẩu trên các hệ điều hành Linux và Windows.
- Biết cách sử dụng công cụ để Crack mật khẩu trên các hệ điều hành Linux và Windows.

2. Nội dung thực hành

2.1. Cơ sở lý thuyết: Công cụ tấn công mật khẩu

a. OphCrack

OphCrack là một công cụ mã nguồn mở dùng để khôi phục mật khẩu trong hệ thống Windows. Đặc biệt, nó được sử dụng để phá mật khẩu của người dùng trên các phiên bản của hệ điều hành Windows bằng cách sử dụng kỹ thuật khai thác lỗ hổng mật khẩu. OphCrack sử dụng một phương pháp gọi là "bảng màu" hoặc "rainbow table" để tìm kiếm và phục hồi mật khẩu đã mã hóa bằng cách sử dụng thuật toán băm.

OphCrack có giao diện đồ họa và rất dễ sử dụng, crack mật khẩu rất nhanh tuy nhiên các rainbow của nó khá tốn dung lượng.

Ophcrack có một số đặc điểm đáng chú ý sau:

- Mã nguồn mở: Ophcrack là một phần mềm mã nguồn mở, điều này có nghĩa là mã nguồn của nó được công bố công khai và có thể được sửa đổi, phát triển bởi cộng đồng người dùng. Điều này tạo điều kiện cho sự minh bạch và kiểm soát mã nguồn.
- Hỗ trợ đa nền tảng: Ophcrack có sẵn cho nhiều nền tảng hệ điều hành, bao gồm Windows, Linux và macOS. Điều này cho phép người dùng sử dụng nó trên các hệ thống khác nhau.
- Tích hợp tấn công từ điển và bảng mã rainbow: Ophcrack thực hiện việc khôi phục mật khẩu bằng cách sử dụng cả tấn công từ điển và tấn công bảng mã rainbow. Điều này tăng cơ hội khôi phục mật khẩu thành công.
- Giao diện đồ họa dễ sử dụng: Ophcrack cung cấp một giao diện người dùng đồ họa (GUI) thân thiện và dễ sử dụng, không yêu cầu người dùng phải có kiến thức kỹ thuật sâu.
- Hiệu suất và thời gian khôi phục: Thời gian để khôi phục mật khẩu có thể biến đổi tùy thuộc vào độ phức tạp của mật khẩu và khả năng của máy tính. Tuy

nhien, Ophcrack thường có hiệu suất khá tốt trong việc khôi phục mật khẩu.

- Cập nhật định kỳ: Ophcrack thường được cập nhật để hỗ trợ các phiên bản mới của hệ điều hành Windows và để cải thiện hiệu suất cũng như bảo mật

b. PWDUMP

PWDUMP là một công cụ phần mềm dùng để thu thập thông tin về mật khẩu từ hệ thống Windows. Cụ thể, nó thường được sử dụng để thu thập và trích xuất mật khẩu đã được mã hóa từ cơ sở dữ liệu của hệ thống Windows. Thông qua việc sử dụng PWDUMP, người dùng có thể thu thập các mật khẩu này để phục vụ cho các mục đích kiểm tra bảo mật, phân tích hoặc khôi phục mật khẩu.

c. Hashcat

Hashcat là phần mềm crack hash/khôi phục mật khẩu từ hash nhanh nhất và tiên tiến nhất hiện nay trên giao diện dòng lệnh. Hashcat cung cấp cho người sử dụng 5 chế độ tấn công/khôi phục mật khẩu khác nhau áp dụng cho hơn 300 thuật toán hash khác nhau. Hashcat là một phần mềm mã nguồn mở và hoàn toàn miễn phí. Hashcat có thể được sử dụng trên nhiều nền tảng khác nhau như Linux, Windows và MacOS.

Ở thời điểm hiện tại, Hashcat có thể sử dụng GPU, CPU và các phần cứng tăng tốc độ tính toán khác trên hệ thống máy tính để tăng tốc độ phá password hash. Tuy nhiên, vì phần lớn chúng ta sử dụng máy ảo Kali Linux trên Virtual Box, nên chúng ta sẽ mất đi sự hỗ trợ đặc lực của GPU (card đồ họa).

Trước khi sử dụng Hashcat, chúng ta phải xác định thuật toán mã hóa, có thể sử dụng công cụ: Hash Identifier (ở ngay trên Kali), Hash Analyzer của TunnelsUP.com (online), Password hash identification (online)

Hash cat hỗ trợ 4 hình thức crack hash:

- **Dictionary (-a 0):** Bạn sẽ cung cấp cho Hashcat một danh sách (có thể là tập hợp những passwords hay được dùng nhất). Hashcat sẽ sử dụng lần lượt từng giá trị trong danh sách này để hash nó với thuật toán đã chỉ định và so sánh với hash đầu vào, nếu kết quả sai, Hashcat sẽ thử giá trị tiếp theo trong danh sách được cung cấp, nếu đúng thì Hashcat trả lại kết quả đã tạo nên giá trị hash trùng khớp với giá trị hash đầu vào.
- **Combination (-a 1):** Tương tự như Dictionary attack ở trên, tuy nhiên khi dùng Combination các bạn sẽ phải cung cấp 2 danh sách chứ không phải chỉ 1 danh sách như Dictionary attack. Hình thức tấn công này được sử dụng khi bạn muốn tìm username và password của người dùng. Lúc này bạn sẽ cần 1 danh sách những usernames hay được dùng nhất và 1 danh sách những passwords hay được dùng nhất. Hashcat sẽ lần lượt tạo ra các cặp kết hợp giữa danh sách username và danh sách password và lần lượt thử đăng nhập bằng các cặp kết hợp

này cho đến khi tìm ra được username và password chính xác hoặc cho đến khi tất cả các cặp kết hợp đều đã được thử và không có cặp nào chính xác.

- **Mask (-a 3):** Mask attack tương tự như Brute force attack, bạn sẽ cung cấp một loạt các ký tự ví dụ a, b, c, d, e, f, 1, 2, 3, v.v. và từ các ký tự được cung cấp này, Hashcat sẽ tự kết hợp các ký tự lại với nhau và tạo ra các chuỗi ký tự ngẫu nhiên ví dụ như abc123, và các chuỗi này sẽ được dùng để tấn công giống như Dictionary attack. Cách tấn công này sẽ phù hợp để tìm những username và password không nằm trong danh sách được cung cấp khi tấn công Dictionary attack, tuy nhiên sẽ rất mất thời gian.
- **Hybrid (-a 6 và -a 7):** Kết hợp cả Dictionary attack và Mask attack.

Cú pháp cơ bản:

hashcat -a <tấn-công> -m <thuật-toán-hash> <file-chứa-hash-đầu-vào> <danh-sách hoặc chuỗi-ký-tự>

Theo đó ta có các thành phần bắt buộc phải có như sau:

- **-a:** Số của hình thức tấn công:
 - **-a 0:** Dictionary
 - **-a 1:** Combination
 - **-a 3:** Mask
 - **-a 6 và -a 7:** Dictionary + Mask
- **-m:** Số của thuật toán hash (bất cứ khi nào quên, bạn đều có thể tra cứu lại bằng lệnh **hashcat -help**). Trong ví dụ mình dùng -m 0 để chỉ thuật toán hash MD5.
- **File chứa hash đầu vào**
- **File chứa danh sách nếu tấn công Dictionary hoặc chuỗi ký tự nếu tấn công Mask**

VD: `hashcat -a 0 -m 0 file-chứa-hash file-danh-sách`

Chú ý: trên Kali cũng có 1 danh sách mật khẩu: `/usr/share/wordlists/rockyou.txt`

d. John The Ripper

John the Ripper là một công cụ phần mềm bẻ khóa mật khẩu miễn phí. Đây cũng là một công cụ trên giao diện dòng lệnh và cũng có thể được cài trên nhiều hệ điều hành khác nhau như MacOS, Windows và Linux.

John The Ripper được thiết kế rất dễ sử dụng và có tích hợp cả tính năng tự động nhận diện thuật toán hash, thế nên chúng ta không cần phải xác định thuật toán rồi mới crack giống như Hashcat. Nó cũng hỗ trợ rất nhiều thuật toán mã hóa:

```
(tranhthuphuong@tranhthuphuong151)-[~]
$ john --list=formats
descript, bsdictcrypt, md5crypt, md5crypt-long, bcrypt, scrypt, LM, AFS,
tripcode, AndroidBackup, adxcrypt, agilekeychain, aix-ssh1, aix-ssh256,
aix-ssh512, andOTP, ansible, argon2, as400-des, as400-ssh1, asa-md5,
AxCrypt, AzureAD, BestCrypt, BestCryptVE4, bfegg, Bitcoin, BitLocker,
bitshares, Bitwarden, BKS, Blackberry-ES10, WoWSPR, Blockchain, chap,
Clipperz, cloudkeychain, dynamic_n, cq, CRC32, cryptoSafe, sha1crypt,
sha256crypt, sha512crypt, Citrix_NS10, dahua, dashlane, diskcryptor, Django,
django-scrypt, dmd5, dmg, dominosec, dominosec8, DPAPImk, dragonfly3-32,
dragonfly3-64, dragonfly4-32, dragonfly4-64, Drupal7, eCryptfs, eigrp,
electrum, EncFS, enpass, EPI, EPiServer, ethereum, fde, Fortigate256,
Fortigate, FormSpring, FVDE, geli, gost, gpg, HAVAL-128-4, HAVAL-256-3, hdaa,
hMailServer, hsrp, IKE, ipb2, itunes-backup, iwork, KeePass, keychain,
keyring, keystore, known_hosts, krb4, krb5, krb5asrep, krb5pa-sha1, krb5tgs,
```

- Tấn công từ điển: Nó lấy các mẫu chuỗi văn bản (trong danh sách từ điển), mã hóa nó theo cùng định dạng với mật khẩu đang được kiểm tra, rồi so sánh đầu ra với chuỗi mật khẩu được mã hóa.
- John cũng có chế độ vét cạn: nó sẽ thử tất cả các tổ hợp có thể của các ký tự, đem đi mã hóa rồi so sánh mật khẩu đã mã khóa cho đến khi tìm ra mật khẩu chính xác. Cách này rất tốn thời gian.

Cú pháp sử dụng:

- Không chỉ định thuật toán crack: sẽ rất tốn thời gian

John path/to/password-file

- Chỉ định thuật toán crack:

john --format=<Format> path/to/password-file

- Crack mật khẩu sử dụng 1 danh sách từ điển:

john --format=FORMAT --wordlist=mywordlist.txt path/to/password-file

Trong đó, **--format=FORMAT** là định dạng của mật khẩu bạn muốn crack (ví dụ:

--format=md5, --format=sha512,...), và **path/to/password-file** là đường dẫn đến tệp chứa mật khẩu.

2.2. Các bước thực hiện

2.2.1. Chuẩn bị môi trường

- Cài đặt công cụ ảo hóa.
- Phần mềm hệ điều hành Linux và Windows.
- Cài đặt các công cụ Crack mật khẩu trên hệ điều hành Linux
- Cài đặt các công cụ Crack mật khẩu trên hệ điều hành Windows

2.2.2. Crack mật khẩu trên Windows

Thử nghiệm crack mật khẩu trên hệ điều hành Windows với ít nhất 3 trường hợp mật khẩu có chiều dài là 4 ký tự, 6 ký tự và 8 ký tự,... Các tên tài khoản này đều có phần đầu là mã sinh viên.

```
(kali@B22DCAT164-HoangAnhKhoa-kali)-[~]
$ sudo useradd B22DCAT164_u1

(kali@B22DCAT164-HoangAnhKhoa-kali)-[~]
$ sudo passwd B22DCAT164_u1
New password:
Retype new password:
passwd: password updated successfully

(kali@B22DCAT164-HoangAnhKhoa-kali)-[~]
$ sudo useradd B22DCAT164_u2

(kali@B22DCAT164-HoangAnhKhoa-kali)-[~]
$ sudo passwd B22DCAT164_u2
New password:
Retype new password:
passwd: password updated successfully

(kali@B22DCAT164-HoangAnhKhoa-kali)-[~]
$ sudo useradd B22DCAT164_u3

(kali@B22DCAT164-HoangAnhKhoa-kali)-[~]
$ sudo passwd B22DCAT164_u3
New password:
Retype new password:
passwd: password updated successfully

(kali@B22DCAT164-HoangAnhKhoa-kali)-[~]
$ █

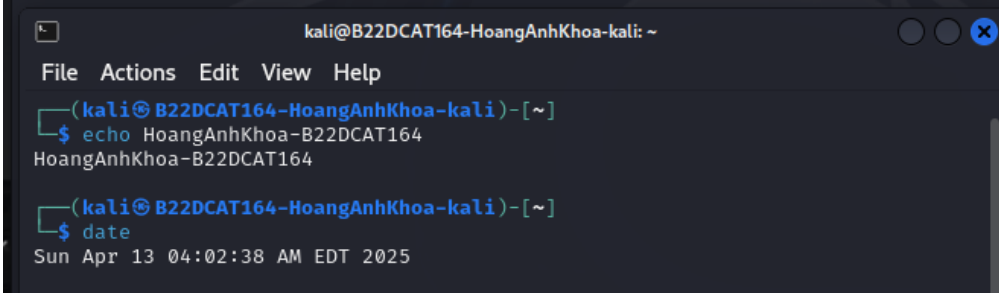
kali@B22DCAT164-HoangAnhKhoa-kali: ~
File Actions Edit View Help

(kali@B22DCAT164-HoangAnhKhoa-kali)-[~]
$ echo HoangAnhKhoa-B22DCAT164
HoangAnhKhoa-B22DCAT164

(kali@B22DCAT164-HoangAnhKhoa-kali)-[~]
$ date
Sun Apr 13 04:02:38 AM EDT 2025
```

```
(kali@B22DCAT164-HoangAnhKhoa-kali)-[~]
$ sudo cat /etc/shadow | grep 'B22DCAT164'
B22DCAT164_u1:$y$j9T$9g50B.o7cxQe70D/Ab1f41$Zeb1c7fkWkaU9NPLjFov2PFyWvwaovcv5/3qwmZSm0:20191:0:
99999:7:::
B22DCAT164_u2:$y$j9T$Mk8aRqGe44VwMjxy6C0090$amCAH8js9h01prDUXMsltbiSc8rzotbeji8kHIYAli3:20191:0:
99999:7:::
B22DCAT164_u3:$y$j9T$w3X/vhuUhpjqVQPdeJg7A/$6J.FC.7XBxlYcsRMRJCeP/ayhcdWYJidDVVnhQLGd1:20191:0:
99999:7:::

(kali@B22DCAT164-HoangAnhKhoa-kali)-[~]
$
```



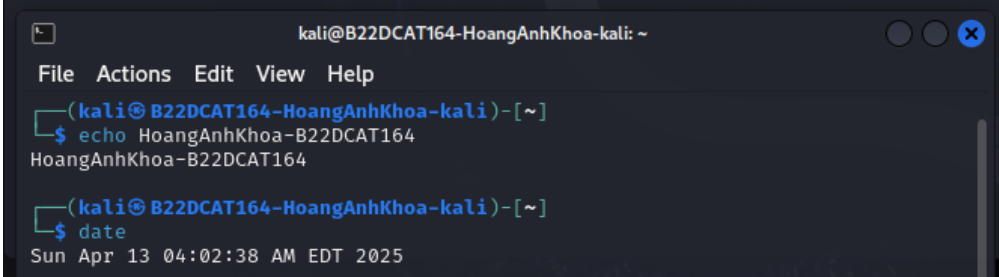
A terminal window titled 'kali@B22DCAT164-HoangAnhKhoa-kali: ~' with a menu bar (File, Actions, Edit, View, Help). It shows the execution of 'echo HoangAnhKhoa-B22DCAT164' and 'date', which outputs 'Sun Apr 13 04:02:38 AM EDT 2025'.

```
(kali@B22DCAT164-HoangAnhKhoa-kali)-[~]
$ sudo grep 'B22DCAT164' /etc/shadow > hashed.txt

(kali@B22DCAT164-HoangAnhKhoa-kali)-[~]
$ ls
B22DCAT164.pcap  Documents  Music  Pictures  Videos
backup          Downloads  ngrok-v3-stable-linux-amd64.tgz  Public
Desktop        hashed.txt  passlist.txt  Templates

(kali@B22DCAT164-HoangAnhKhoa-kali)-[~]
$ cat hashed.txt
B22DCAT164_u1:$y$j9T$9g50B.o7cxQe70D/Ab1f41$Zeb1c7fkWkaU9NPLjFov2PFyWvwaovcv5/3qwmZSm0:20191:0:
99999:7:::
B22DCAT164_u2:$y$j9T$Mk8aRqGe44VwMjxy6C0090$amCAH8js9h01prDUXMsltbiSc8rzotbeji8kHIYAli3:20191:0:
99999:7:::
B22DCAT164_u3:$y$j9T$w3X/vhuUhpjqVQPdeJg7A/$6J.FC.7XBxlYcsRMRJCeP/ayhcdWYJidDVVnhQLGd1:20191:0:
99999:7:::

(kali@B22DCAT164-HoangAnhKhoa-kali)-[~]
$
```



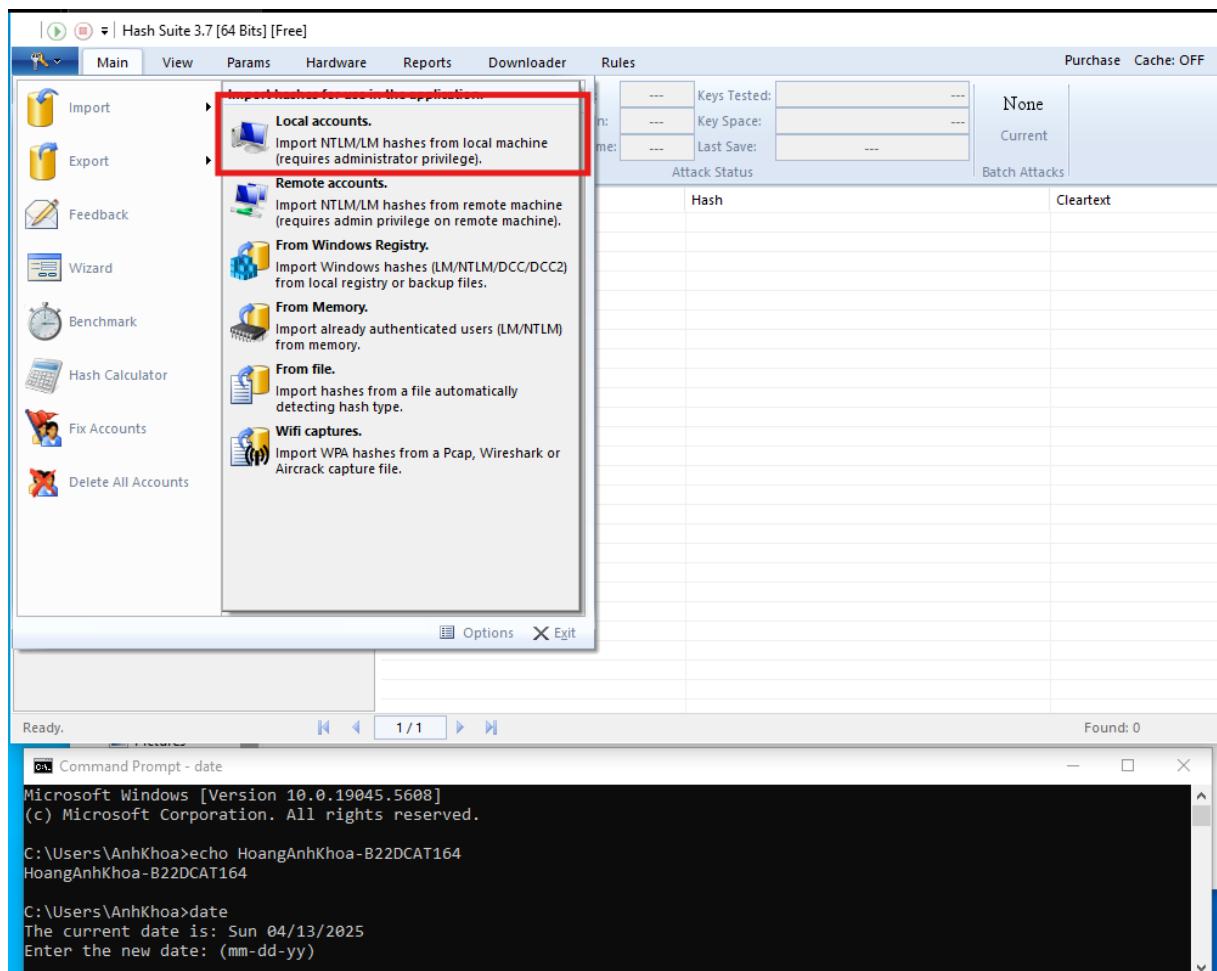
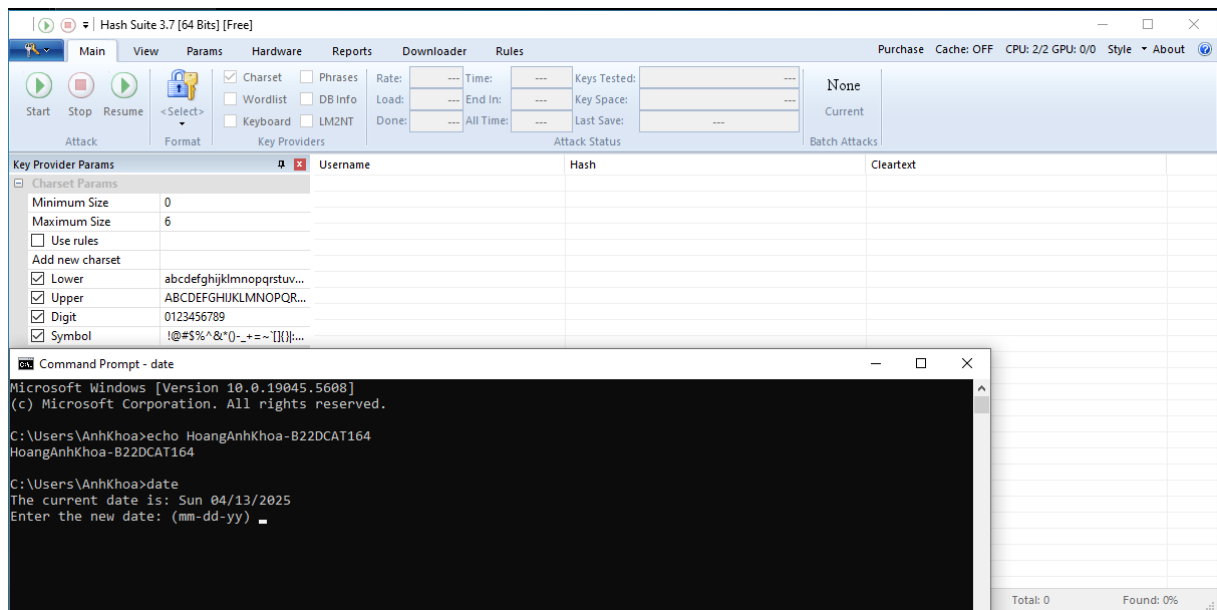
A terminal window titled 'kali@B22DCAT164-HoangAnhKhoa-kali: ~' with a menu bar (File, Actions, Edit, View, Help). It shows the execution of 'ls' displaying a directory listing, and 'cat hashed.txt' displaying the contents of the file created in the previous window.


```
kali@B22DCAT164-HoangAnhKhoa-kali: ~  
File Actions Edit View Help  
(kali@B22DCAT164-HoangAnhKhoa-kali)-[~]  
$ john --format=crypt hashed.txt  
  
Using default input encoding: UTF-8  
Loaded 3 password hashes with 3 different salts (crypt, generic crypt(3) [?/64])  
Cost 1 (algorithm [1:descript 2:md5crypt 3:sunmd5 4:bcrypt 5:sha256crypt 6:sha512crypt]) is 0 for all loaded hashes  
Cost 2 (algorithm specific iterations) is 1 for all loaded hashes  
Will run 4 OpenMP threads  
Proceeding with single, rules:Single  
Press 'q' or Ctrl-C to abort, almost any other key for status  
0g 0:00:03:45 98.69% 1/3 (ETA: 04:57:52) 0g/s 229.5p/s 229.5c/s 229.5C/s b999991917..u999991913  
Almost done: Processing the remaining buffered candidate passwords, if any.  
Proceeding with wordlist:/usr/share/john/password.lst  
password (B22DCAT164_u3)  
passwd (B22DCAT164_u2)  
pass (B22DCAT164_u1)  
3g 0:00:04:15 DONE 2/3 (2025-04-13 04:58) 0.01174g/s 218.7p/s 229.7c/s 229.7C/s modem..sony  
Use the "--show" option to display all of the cracked passwords reliably  
Session completed.  
  
(kali@B22DCAT164-HoangAnhKhoa-kali)-[~]  
$  
  
kali@B22DCAT164-HoangAnhKhoa-kali: ~  
File Actions Edit View Help  
(kali@B22DCAT164-HoangAnhKhoa-kali)-[~]  
$ echo HoangAnhKhoa-B22DCAT164  
HoangAnhKhoa-B22DCAT164  
  
(kali@B22DCAT164-HoangAnhKhoa-kali)-[~]  
$ date  
Sun Apr 13 04:02:38 AM EDT 2025
```

2.2.3. Crack mật khẩu trên Windows

Thử nghiệm crack mật khẩu trên hệ điều hành Linux với ít nhất 3 trường hợp mật khẩu có chiều dài là 4 ký tự, 6 ký tự và 8 ký tự,... Các tên tài khoản này đều có phần đầu là mã sinh viên.

```
Microsoft Windows [Version 10.0.19045.5608]  
(c) Microsoft Corporation. All rights reserved.  
  
C:\Windows\system32>net user B22DCAT164_u1 1234 /add  
The command completed successfully.  
  
C:\Windows\system32>net user B22DCAT164_u2 123456 /add  
The command completed successfully.  
  
C:\Windows\system32>net user B22DCAT164_u2 12345678 /add  
The account already exists.  
  
More help is available by typing NET HELPMSG 2224.  
  
C:\Windows\system32>net user B22DCAT164_u3 12345678 /add  
The command completed successfully.  
  
Command Prompt - date  
Microsoft Windows [Version 10.0.19045.5608]  
(c) Microsoft Corporation. All rights reserved.  
  
C:\Users\AnhKhoa>echo HoangAnhKhoa-B22DCAT164  
HoangAnhKhoa-B22DCAT164  
  
C:\Users\AnhKhoa>date  
The current date is: Sun 04/13/2025  
Enter the new date: (mm-dd-yy) _
```



Hash Suite 3.7 [64 Bits] [Free] Importer

Main View Params Hardware Reports Downloader Rules Statistics Purchase Cache: OFF CPU: 2/2 GPU: 0/0 Style About

Start Stop Resume NTLM Wordlist Phrases DB Info LM2NT Keyboard Key Providers Attack Status Batch Attacks

Key Provider Params

Charset Params

Minimum Size 0

Maximum Size 6

Use rules

Add new charset

Lower abcdefghijklmnopqrstuv...

Upper ABCDEFGHIJKLMNOPQR...

Digit 0123456789

Symbol !@#\$%^&*()-_+=~[]{}|;:'",./\>

Wordlist Params

Keyboard Params

Phrases Params

DB Info Params

LM2NT Params

Rules

Username	Hash	Cleartext
Administrator	31D6CFE0D16AE931B73C59D7E0C089C0	????????????????????????????
AnhKhoa	31D6CFE0D16AE931B73C59D7E0C089C0	????????????????????????????
DefaultAccount	31D6CFE0D16AE931B73C59D7E0C089C0	????????????????????????????
Guest	31D6CFE0D16AE931B73C59D7E0C089C0	????????????????????????????
B22DCAT164_u1	7CE21F17C0AEE7F89CEBA532D0546AD6	????????????????????????????
B22DCAT164_u2	32ED87BD85FDC5E9CBA88547376818D4	????????????????????????????
B22DCAT164_u3	259745CB123A52AA2E693AAACCA2DB52	????????????????????????????
WDAGUtilityAccount	6672DBDC40E70F3D3C7649F798896400	????????????????????????????

Ready. Found: 0 Total: 5 Found: 0%

Command Prompt - date

Microsoft Windows [Version 10.0.19045.5608]
(c) Microsoft Corporation. All rights reserved.

C:\Users\AnhKhoa>echo HoangAnhKhoa-B22DCAT164
HoangAnhKhoa-B22DCAT164

C:\Users\AnhKhoa>date
The current date is: Sun 04/13/2025
Enter the new date: (mm-dd-yy)

Hash Suite 3.7 [64 Bits] [Free] Importer

Main View Params Hardware Reports Downloader Rules Statistics Purchase Cache: OFF CPU: 2/2 GPU: 0/0 Style About

Start Stop Resume NTLM Wordlist Phrases DB Info LM2NT Keyboard Key Providers Attack Status Batch Attacks

Key Provider Params

Charset Params

Minimum Size 0

Maximum Size 6

Use rules

Add new charset

Lower abcdefghijklmnopqrstuv...

Upper ABCDEFGHIJKLMNOPQR...

Digit 0123456789

Symbol !@#\$%^&*()-_+=~[]{}|;:'",./\>

Wordlist Params

Keyboard Params

Phrases Params

DB Info Params

LM2NT Params

Rules

Username	Hash	Cleartext
Administrator	31D6CFE0D16AE931B73C59D7E0C089C0	
AnhKhoa	31D6CFE0D16AE931B73C59D7E0C089C0	
DefaultAccount	31D6CFE0D16AE931B73C59D7E0C089C0	
Guest	31D6CFE0D16AE931B73C59D7E0C089C0	
B22DCAT164_u1	7CE21F17C0AEE7F89CEBA532D0546AD6	1234
B22DCAT164_u2	32ED87BD85FDC5E9CBA88547376818D4	????????????????????????????
B22DCAT164_u3	259745CB123A52AA2E693AAACCA2DB52	????????????????????????????
WDAGUtilityAccount	6672DBDC40E70F3D3C7649F798896400	????????????????????????????

Cracking... Found: 2 Total: 5 Found: 40%

Command Prompt - date

Microsoft Windows [Version 10.0.19045.5608]
(c) Microsoft Corporation. All rights reserved.

C:\Users\AnhKhoa>echo HoangAnhKhoa-B22DCAT164
HoangAnhKhoa-B22DCAT164

C:\Users\AnhKhoa>date
The current date is: Sun 04/13/2025
Enter the new date: (mm-dd-yy)

3. Kết luận

- Lý thuyết về các công cụ crack mật khẩu trên Windows, Kali Linux
- Crack mật khẩu thành công trên Windows
- Crack mật khẩu thành công

4. Tài liệu tham khảo

- Crack mật khẩu trên Windows:
[xem tại đây](#)
- Crack mật khẩu trên Linux: [Xem tại đây](#)
- Chương 2, Giáo trình cơ sở an toàn thông tin, Học viện Công Nghệ Bưu Chính Viễn Thông, 2020 của tác giả Hoàng Xuân Dậu
- Chapter 11 Authentication and Remote Access, sách Principles of Computer Security CompTIA Security+ and Beyond Lab Manual (Exam SY0-601) by Jonathan S. Weissman